

## INFORMATION ASSURANCE AND SECURITY 2 (Key Principles of Secure Systems)

### KEY PRINCIPLES OF SECURE SYSTEMS

- List of fundamental principle
- Key aspects
- Benefits and implementation

#### Introduction

Designing secure systems involves several key principles that ensure data integrity, confidentiality, and availability

Short explanation: Data integrity ensures information is accurate and unaltered, confidentiality protects it from unauthorized access, and availability ensures it is accessible when needed.

#### Principle of Least Privilege(PoLP)

##### 1. Least Privilege

- ◆ **Grant users and systems the minimum level of access—or privileges—necessary to perform their functions. This limits potential damage from accidents or malicious actions.**

Example: A customer service employee can view customer records but cannot edit or delete them, reducing the chance of mistakes or misuse.

- ◆ **Least Privilege is a fundamental concept in information security and access control. It dictates that users, systems, and processes should be granted the minimum access or privileges necessary to perform their required functions**

Example: In a school, teachers can access student grades, but only the IT staff can access and change system settings or network configurations, following the principle of least privilege.

#### Key Aspects of Least Privilege

- ◆ User Accounts and Roles
- ◆ System and Process Permissions
- ◆ Temporary Elevation of Privileges
- ◆ Segregation of Duties
- ◆ Regular Review and Adjustment

##### 1. User Accounts and Roles

- ◆ **Users should only have access to the essential information and resources for their job roles.**
- ◆ **Role-Based Access Control (RBAC) can be used to assign privileges based on job functions.**

Example: A school clerk can access student records but not teacher payroll files, because their role only requires access to student information.

##### 2. System and Process Permissions

- ◆ **Applications and processes should run with the least privileges required for their tasks.**
- ◆ **This reduces the risk that an exploit of a particular service could compromise the entire system.**

Example: A web browser runs with limited user permissions instead of full system access, so if it's hacked, the attacker can't control the whole computer.

An antivirus program only gets permission to scan and remove threats, not to change system settings, so even if it's compromised, it can't damage the entire system.

##### 3. Temporary Elevation of Privileges

- ◆ **Users or processes should be able to temporarily elevate their privileges when necessary, but this elevation should be restricted in scope and time.**
- ◆ **For instance, a user might temporarily gain administrative access to perform a specific task but revert to lower privileges once the task is completed.**

Example: An IT technician may be given administrator access for 30 minutes to install software, and afterward, their access automatically returns to normal to prevent misuse.

##### 4. Segregation of Duties

- ◆ **Critical tasks should be divided among multiple users or systems to ensure no single point of failure or compromise.**

- ◆ **This segregation helps prevent insider threats and fraud by requiring collusion for malicious activities.**

Example: In a bank, one employee prepares a payment, but a different employee must approve it — this way, no single person can transfer money alone, helping prevent fraud.

## **5. Regular Review and Adjustment**

- ◆ **Regularly audit and review access controls and privileges to ensure they remain aligned with current roles and responsibilities.**
- ◆ **Remove unnecessary privileges promptly when they are no longer needed.**

Example: When an employee transfers to a different department, their old access to previous files and systems should be removed during a regular access review.

## **Benefits of Least Privilege**

- ◆ **Minimized Attack Surface**
- ◆ **Damage Containment**
- ◆ **Improved Stability and Reliability**
- ◆ **Regulatory Compliance**

### **1. Minimized Attack Surface**

- ◆ **Limiting privileges reduces the number of potential entry points for attackers.**
- ◆ **Fewer privileges mean fewer opportunities for malware to exploit.**

Example: If a staff member can only view documents but not download or edit them, malware on their device can't change or steal sensitive files.

### **2. Damage Containment**

- ◆ **If an account or process is compromised, the damage is limited to the scope of the privileges granted.**
- ◆ **For example, a user with limited access cannot modify system settings or access sensitive data outside their domain.**

Example: If a receptionist's email account is hacked, the attacker can't access payroll or confidential HR files because the account doesn't have permission to view them.

### **3. Improved Stability and Reliability**

- ◆ **Reducing the number of users and processes with high-level privileges decreases the risk of accidental changes that could destabilize the system.**
- ◆ **It also helps in maintaining the integrity of the system by reducing the likelihood of errors.**

Example: Only the IT administrator can change system settings, so regular employees can't accidentally delete important configurations or files.

### **4. Regulatory Compliance**

- ◆ **Many regulations and standards (such as GDPR, HIPAA, and PCI-DSS) mandate the implementation of least privilege to protect sensitive information.**
- ◆ **Adhering to this principle helps organizations stay compliant with legal and regulatory requirements.**
- **Short explanation: Implementing least privilege helps organizations meet legal requirements like GDPR or HIPAA by ensuring only authorized users can access sensitive data. GDPR – General Data Protection Regulation, HIPAA – Health Insurance Portability and Accountability Act, PCI-DSS – Payment Card Industry Data Security Standard**

Example: In a hospital, only doctors and nurses assigned to a patient can view their medical records, helping the hospital comply with HIPAA privacy rules.

## **Implementing Least Privilege**

- ◆ **Access Control Lists (ACLs)**

- ◆ **User Account Management**
- ◆ **Privileged Access Management (PAM)**
- ◆ **Continuous Monitoring and Auditing**

#### **1. Access Control Lists (ACLs)**

- ◆ **Define and enforce permissions for users and groups based on their roles and responsibilities.**

Example: In a school, teachers can access student grades and lesson plans, while students can only view their own grades and class schedules.

#### **2. User Account Management**

- ◆ **Create and manage user accounts with appropriate privileges.**
- ◆ **Use temporary accounts or just-in-time access for short-term needs.**

Example: A school IT staff gives a temporary account with limited access to a guest speaker for a one-day workshop, then disables it afterward.

#### **3. Privileged Access Management (PAM)**

- ◆ **Utilize PAM tools to control and monitor access to critical systems and data.**
- ◆ **Implement just-in-time access, session recording, and auditing for privileged accounts.**

Example: A school's IT department uses a PAM tool to give temporary admin access to a technician for system updates, while recording the session for security review.

#### **4. Continuous Monitoring and Auditing**

- ◆ **Regularly review logs and access records to detect and respond to any unauthorized or unusual activities.**
- ◆ **Perform periodic audits to ensure that access controls are enforced correctly.**

Example: A school's IT team reviews login logs every Friday to spot any unusual after-hours access and conducts a quarterly audit to confirm that only current teachers can view student grades.

### **How does the principle of least privilege (PoLP) work?**

- ◆ **The principle of least privilege works by limiting the accessible data, resources, applications and application functions to only that which a user or entity requires to execute their specific task or workflow. Without incorporating the principle of least privilege, organizations create over-privileged users or entities that increase the potential for breaches and misuse of critical systems and data.**
- ◆ **The principle of least privilege as executed within Zero Trust Network Access (ZTNA) 2.0 (ZTNA 2.0) eliminates the need for administrators to think about the network architecture or low-level network constructs such as FQDN, ports or protocols, enabling fine-grained access control for comprehensive least-privileged access.**

Example: A finance employee using ZTNA 2.0 can only access the company's accounting application—not the HR or engineering systems—without needing to know server IPs or ports, ensuring access is limited strictly to what they need for their job.

### **Where to Start a PoLP Implementation**

- ◆ **VPN technology replacement is a good starting point for implementing the principle of least privilege within your organization. Replace legacy remote access outdated VPN technologies with a more modern ZTNA 2.0 solution to overcome performance bottlenecks and simplify management.**

Example: Instead of giving all remote employees full network access through a VPN, a company uses ZTNA 2.0 to let a sales rep access only the (Customer Relationship Management) CRM app they need—nothing more.